

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

Threat Feed Managment
Eray Atalay





İçindekiler

İçindekiler	1
1. Veri Kirliliği ve İstihbarat İhtiyacı	2
2. Veri Kaynakları ve Çeşitliliği	2
Açık Kaynak İstihbaratı (OSINT)	2
Ticari (Ücretli) Kaynaklar	2
Sektörel Veri Kaynakları (ISACs)	2
3. Yaşam Döngüsü ve Teknik Süreç	3
Normalizasyon ve Ayrıştırma	4
STIX Veri Modeli	4
Tekilleştirme	4
Zenginleştirme	4
Puanlama ve Doğrulama	5
Dağıtım ve Entegrasyon	5
4. Kalite Metrikleri	5
Güncellik	5
Bağlam	6
Doğruluk	6
5. Entegrasyon ve Otomasyon	6
Threat Intelligence Platform (TIP)	6
SOAR (Security Orchestration, Automation and Response)	7
Kritik Entegrasyon Noktaları	7
6. Zorluklar	7
Veri Fazlalığı	7
Saldırganların Adaptasyonu	8
7. Sonuç	8
Kaynakça	9



1. Veri Kirliliđi ve İstihbarat İhtiyacı

Siber tehdit istihbaratı alanında her gün milyonlarca IoC üretiliyor. Bunların hangisinin güvenilir olduğunu bilmek zor. Topladığımız kirli veriyle SOC ortamlarını beslemek verimsiz. Bu konuyu çözebilmek için elimizdeki fazlaca veriyi aksiyon alınabilir istihbarata (actionable intelligence) çevirmekte yardımcı olan sisteme threat feed management denir.

2. Veri Kaynakları ve Çeşitliliđi

İstihbaratın başarısı, kaynakların çeşitliliğine ve bu kaynakların kurumun saldırı yüzeyiyle ne kadar örtüştüğü ile doğrudan bağlantılıdır. Kaynakları genel olarak üç ana kategoride ele alabiliriz.

Açık Kaynak İstihbaratı (OSINT)

Herkesin erişebildiğı açık, topluluk odaklı kaynaklardır. Genellikle ücretsizdir, çok geniş bir veri havuzu vardır ve küresel çapta olayları anında yansıtır. Bunların yanında çok fazla gereksiz veri ve “false positive” içerir. Örnek kaynaklar; AbuseIPDB, abuse.ch, bloclist.de.

Ticari (Ücretli) Kaynaklar

Siber güvenlik firmalarının kendi sensör ağıları, bal küpleri (honeypot) ve analiz ekipleri aracılığıyla topladıkları verilerdir. Veriler önceden doğrulanmıştır, yanlış alarm oranı düşüktür, veriler genellikle tehdit aktörleriyle eşleştirilmiştir. Bu kaynakların dezavantajı ise maliyetli olmasıdır. Örnek kaynaklar; CrowdStrike, Mandiant (Google Cloud), Recorded Future, Kaspersky.

Sektörel Veri Kaynakları (ISACs)

Belirli bir endüstriye (finans, sağlık, enerji) yönelik tehditlerin paylaşıldığı kapalı ağlardır. Örneğin bir bankaya saldırı yapıldığında diğer bankalara haber verilip sektörün geneli korunmaya çalışılır.



3. Yaşam Döngüsü ve Teknik Süreç

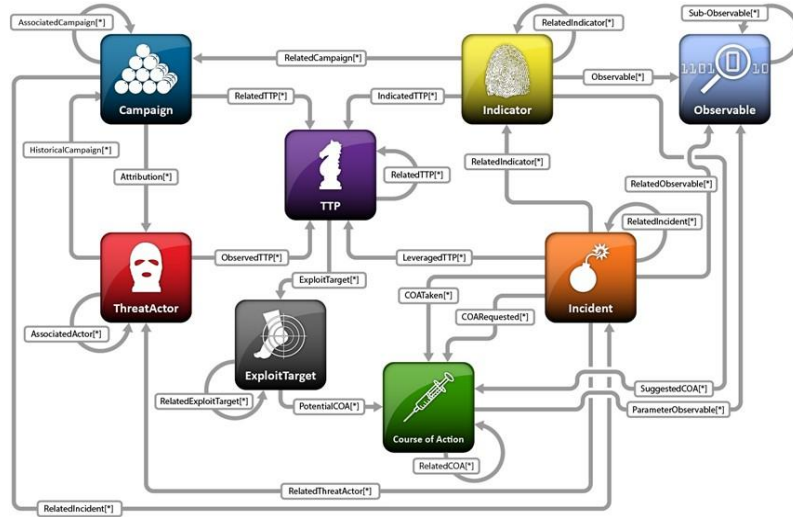


Elimizdeki ham verinin istihbarata dönüştüğü, anlamlandırılıp, belirli bir format üzerinden sunulduğu kısımdır. Siber tehdit istihbaratı yaşam döngüsündeki aşamalara çokça benzer. Bu süreç genelde şu adımlardan oluşur:

Normalizasyon ve Ayırıştırma

Farklı kaynaklardan gelen veriler farklı formatlarda olabilir. JSON, CSV, STIX formatında olabilir. İşte bu aşamada tüm bu veriler ayıklanır ve ortak sistemin anlayacağı bir veri modeline göre düzenlenir

STIX Veri Modeli



Örneğin yukarıdaki görsel STIX veri modelinin ve nesneler arasındaki ilişkileri gösteren bir şemadır. Tehdit istihbaratı verilerinin sadece birer liste olmadığını, saldırgan, yöntem ve müdahale planı gibi unsurların birbirleriyle nasıl karmaşık bir ağ oluşturduğunu gösteren mimari yapıdır.



Tekilleřtirme

Aynı veri örneğın zararlı bir IP adresi birden fazla kaynaktan gelmiş olabilir. Böyle durumlarda aynı veriden birden fazla olması halinde tek hale düşürülmelidir.

Zenginleřtirme

Ham veri yani yine zararlı bir IP adresinden bahsedecek olursak, sadece IP adresi bizim için bir anlam ifade etmez. Bu IP adresini anlamlandırmak için ona bir bağlam kazandırmalıyız. Bu IP hangi ülkeye ait? Hangi ASN (İnternet Servis Sağlayıcısı) üzerinden yayın yapıyor? Daha önce hangi APT grubuyla ilişkilendirilmiş? Gibi veriler, elimizdeki verinin risk değerini açıklar.

Puanlama ve Doğrulama

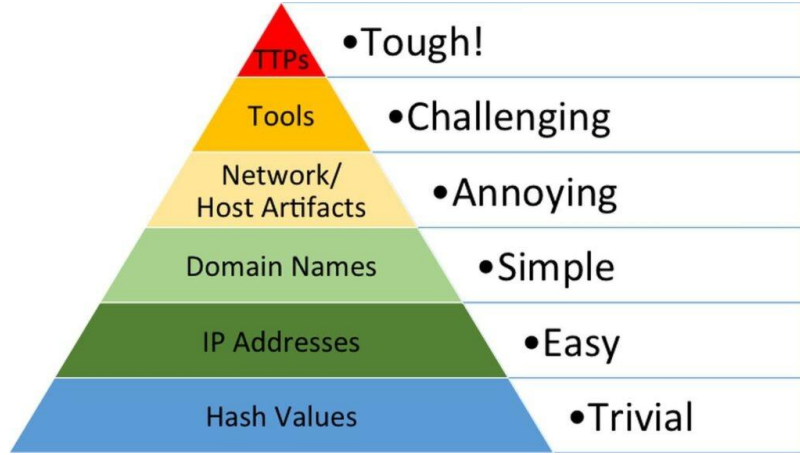
Her tehdit verisi kaynağı aynı güvenilirliğe sahip değildir. Kaynağın geçmişteki doğruluk oranına ve verinin güncelliğine bağlı olarak kaynağa bir güven skoru atanır. Örneğın 10 dakika önce güncellenmiş bir kaynak 90 puan alırken ile 2 hafta önce güncellenmiş bir kaynak 20 puan alabilir.

Dağıtım ve Entegrasyon

İşlenmiş ve doğrulanmış verinin dağıtıldığı kısımdır. Veri otomatik olarak SIEM, EDR, Firewall veya SOAR gibi platformlarına aktarılır.



4. Kalite Metrikleri



David J. Bianco tarafından geliştirilen yukarıdaki bu piramit, tehdit istihbaratındaki verilerin değerini temsil eder. Alt basamaklar (Hash, IP) savunmacı için yönetilmesi kolay ancak saldırgan için değiştirilmesi basit unsurlardır. Threat Feed Managment'te hedef, piramidin en üstündeki TTP (Taktik, Teknik ve Prosedürler) katmanına odaklanarak saldırganın operasyonel maliyetini artırmaktır.

Her veri istihbarat değildir. Kurumlar için verinin kalitesi, kurumun savunma kapasitesini doğrudan etkiler. Düşük kaliteli veri güvenlik ekiplerini yanlış alarmlarla meşgul ederek asıl tehlikelerin gözden kaçmasına neden olur.

Güncellik

Tehdit verisinin saldırı gerçekleşikten ne kadar sonra ulaştığını ölçer. Örneğin bir IP adresi dakikalar içinde temiz bir sunucudan zararlı bir C2 merkezine dönüşebilir. Eğer tehdit verisi 24 saat gecikmeli geliyorsa, saldırgan çoktan hedefine erişmiş olabilir.

Bağlam

Gelen verinin kurumun varlıklarıyla ne kadar örtüştüğünü ölçer. Örneğin sadece macOS kullanan bir kurumun Windows'ta çıkan zafiyetler hakkında sürekli bilgilendirilmesi bir gürültü yaratır. Kuruma ulaşan veriler kurumun sektörüyle, coğrafyasıyla, varlıklarıyla bağlantılı olmalıdır.

Doğruluk

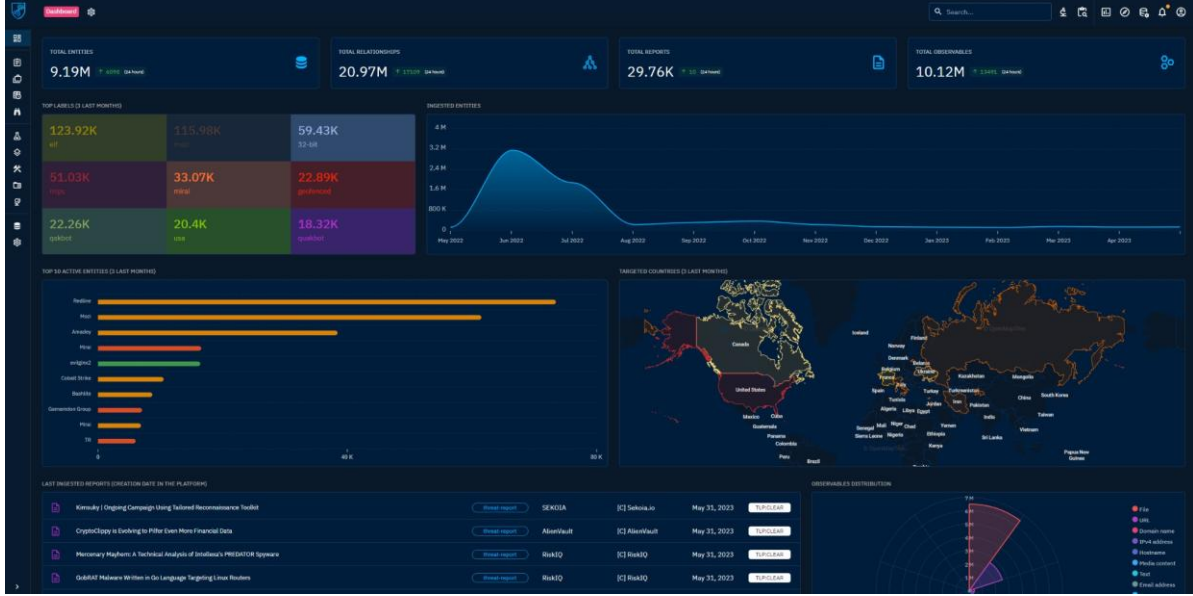
Verinin ne kadar güvenilir olduğunu ve "False Positive" (yanlış alarm) oranını ölçer. Örneğin bir tehdit verisi Google'ın veya Microsoft'un meşru servislerinin zararlı olarak işaretliyorsa bu durum false positive durumudur.



5. Entegrasyon ve Otomasyon

İşlenen verilerin insan müdahalesine gerek kalmadan sistemlere entegre edilmesi gerekmektedir. Bir saldırı esnasında manuel insan müdahalesi beklemek çok yavaş olacağı için bu gibi işlemler otomasyona dökülmelidir.

Threat Intelligence Platform (TIP)



Entegrasyonun kalbi TIP'tır. TIP (Örneğin MISP, OpenCTI), farklı kaynaklardan aldığı verileri işler ve diğer güvenlik araçlarına dağıtır. Burda dağıtımdaki yönetim TIP'dadır. Hangi verinin hangi cihaza gideceğini TIP belirler.



SOAR (Security Orchestration, Automation and Response)

SOAR platformları otomasyon sistemleridir. Tehdit verileri SOAR'lar üzerinde tanımlı scriptleri tetikler.

Örnek Senaryo:

TAXII üzerinden yeni bir zararlı dosya hash'i (IoC) gelir.

SOAR otomatik olarak EDR sistemine bu hash'i sorgular.

Eğer bu dosya kurum içindeki bir bilgisayarda bulunursa, o bilgisayarı otomatik olarak ağdan izole eder.

Analiste sadece "İşlem yapıldı, onaylayın" bildirimi düşer.

Kritik Entegrasyon Noktaları

Tehdit verilerinin aktarıldığı temel sistemler:

SIEM (Security Information and Event Management): Gelen loglarla tehdit verilerini karşılaştırarak korelasyon yapar. (Örn: "Bu IP'den gelen trafik, benim kara listemle eşleşiyor, alarm üret.")

Firewall / IPS: Yüksek güven puanına sahip zararlı IP ve domainlerin otomatik olarak engellenmesini sağlar.

EDR (Endpoint Detection and Response): Zararlı dosyaların son kullanıcı cihazlarında çalışmasını daha başlamadan durdurur.

6. Zorluklar

Threat Feed Managment yöntemi siber savunmada çok kullanılan önemli bir sistem olsa da saldırıların yöntem değiştirmesi ve veri hacminin aşırı artması yeni zorlukları beraberinde getirmiştir.

Veri Fazlalığı

Tehdit verilerinin sayısı arttıkça, bu verileri işlemek donanım kaynaklarını zorlamakta ve sistem performansını düşürmektedir.



Saldırganların Adaptasyonu

Modern saldırırganlar, IP adreslerini ve domainlerini çok hızlı deęiřtirerek (Fast-flux DNS gibi tekniklerle) statik verileri etkisiz hale getirebilmektedir.

7. Sonu

Siber gvenlikte bilgi gtr fakat nemli olan bu bilginin nasıl iřlendięi, hangi formatta, nasıl sunulduęu ve doęru baęlamın kurulabilmiř olduęudur. İřte Threat Feed Managment btn bunları saęlayan sistemin adıdır. Gelecekte de daha fazla veriye sahip olan deęil bu veriye en hızlı ve gvenilir řekilde otonom eylemlere dnřtrebilenler gvende kalacaktır.



Kaynakça

<https://stixproject.github.io/documentation/concepts/relationships/>

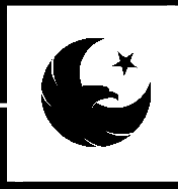
<https://www.bgasecurity.com/2019/05/siber-tehdit-istihbarati-neden-gereklidir-faydalari-nelerdir-bolum-2/>

<https://www.cloudflare.com/learning/security/glossary/threat-intelligence-feed/>

<https://www.rapid7.com/fundamentals/threat-intelligence-feeds/>

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-150.pdf>

<https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>



YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

